

HireOS Interview – Zoom Integration Security Overview

[Company legal name] · Version 1.0 · [Date]

This document describes how the HireOS Interview Zoom app handles Zoom data and how that data is protected. It covers only the Zoom integration: OAuth authorization, interview meetings, the embedded Meeting SDK and Realtime Media Streams (RTMS) transcripts.

1. Purpose of the integration

Interviewers connect their own Zoom account to HireOS. HireOS creates the interview meeting on that account, lets the interviewer host it inside HireOS through the Zoom Meeting SDK, and receives a live transcript of the meeting through RTMS. The transcript is used by the hiring team to review the interview.

2. Zoom data we handle

Data	Source	Purpose	Storage
OAuth access and refresh tokens	Zoom OAuth	Call the Zoom APIs on behalf of the interviewer	Encrypted at rest (AES-256-GCM)
Zoom user ID and display name	GET /v2/users/me	Show which account hosts interviews; identify the host when starting RTMS	Encrypted at rest (AES-256-GCM), together with the tokens
Meeting join URL (meeting ID and passcode)	POST /v2/users/me/meetings	Join the interview meeting; share the link with the candidate	PostgreSQL, plain text
ZAK token	GET /v2/users/me/zak	Let the host start the meeting in the Meeting SDK	Not stored; passed only to the SDK in the browser
Meeting UUID to meeting ID mapping	GET /v2/meetings/{uuid}	Match RTMS events to the interview	In memory only; not stored
Live transcript (speaker display name and text)	RTMS	Interview review, summaries and draft scores	PostgreSQL, plain text
Meeting audio	RTMS	Not used	Not stored

HireOS only acts on meetings it created for an interview. Webhook events for other meetings are ignored.

3. Security controls

Area	Control
Transport	All traffic to HireOS uses HTTPS (TLS, Let's Encrypt certificate). All calls to Zoom and OpenAI use HTTPS/TLS, and RTMS media connections use TLS.
OAuth	Authorization code flow with a single-use, random <code>state</code> value (expires after 5 minutes) to prevent CSRF. The redirect URI is fixed in configuration. Tokens are refreshed automatically and stored encrypted.
Token encryption	Tokens and the Zoom user profile are encrypted with AES-256-GCM. The encryption key is a random 256-bit key stored separately from the data, in a file readable only by the service (permissions 0600).
Webhook verification	Every webhook is verified with the <code>x-zm-signature</code> HMAC-SHA256 signature and timestamp, using a constant-time comparison, before it is processed. The <code>endpoint.url_validation</code> challenge is answered as documented by Zoom.
Meeting SDK	SDK signatures are generated on the server (HS256, 30-minute expiry) and rate-limited. The SDK secret and client secret are never sent to the browser.
Least privilege	Only the scopes needed for the features above are requested. RTMS is started only with the "start" action, only for meetings HireOS created.
Secrets management	The Zoom client secret, webhook secret token, OpenAI API key and database credentials are stored in environment files on the server. They are not in the source repository or the container images.
Network isolation	The application runs in Docker containers on a Linux server in Google Cloud. PostgreSQL and the internal services are reachable only inside the private Docker network; only the HTTPS entry point is public.

4. Third-party processing

Transcript text and the interview's evaluation rubric are sent to the OpenAI API (`api.openai.com`) to draft an interview summary and rubric scores. A person reviews the drafts before they are used. Zoom OAuth tokens, credentials and audio are never sent to OpenAI. OpenAI processes this data under its API terms.

5. Data retention and deletion

[To be confirmed by the company before submission: how long transcripts and meeting links are kept, and how a user or customer can request deletion.]

[Planned, not yet implemented: when a user removes the app from their Zoom account (app deauthorization event), their stored Zoom tokens and profile will be deleted automatically. Only state this as done once it is built.]

6. Contact

Security questions: `[security contact email]`